

TS ACADEMY CAPSTONE PROJECT

VULNERABILITY ASSESSMENT REPORT

Findings from kioptrix and metasploitable 2 Lab assessment

Emmanuel Ademoyega

Assessment Period: 29TH June 2026 – 18TH July 2026

Report Date: July 2026

Executive Summary

This Vulnerability Assessment engagement was conducted using the Kioptrix and Metasploitable 2 laboratory environments to simulate the network infrastructure of Apex Healthcare Solution Limited. The primary objective was to identify Vulnerabilities within exposed systems, assess the level of risk they present to the organization, and recommend practical remediation measures that will strengthen its overall security posture.

The assessment took place between **29 June 2026 and 11, July 2026** and combined different vulnerability validation. Initial reconnaissance was performed using **Nmap** to identify active hosts, open ports, and running services. The identified vulnerabilities were then manually verified. This approach helped eliminate false positives and ensured that the final results accurately reflected the security posture of the Organization

Six vulnerabilities was Confirmed across the two laboratory environments: Kioptrix and metasploitable 2

Metasploitable 2

Vsftpd 2.3.4 Backdoor (FTP) – High

MySQL Unauthenticated Root Access – High

Postfix SMTP VRFY User Enumeration – Low

Kioptrix

OpenSSH 2.9p2 (Protocol 1.99) – High

Apache HTTP Server 1.3.20 with mod_ssl/OpenSSL – Medium

RPCBind Information Disclosure – Medium

Several of these findings successfully identified and demonstrated that an attacker could exploit known weaknesses in outdated software and insecure configurations. Three vulnerabilities were assigned a **High** risk rating because they could allow an attacker to gain unauthorized access to affected systems without requiring valid credentials. Two additional findings were classified as **Medium** due to their potential to facilitate further compromise or expose valuable system information. The remaining **Low**-rated vulnerability does not directly compromise the affected host; however, it enables user account enumeration, providing information that could support password attacks or other forms of unauthorized access.

For an organization such as Apex Healthcare Solution Limited, where the confidentiality, integrity, and availability of patient records and other sensitive business information are essential, these weaknesses represent significant security risks. If left unaddressed, they could lead to unauthorized system access, data breaches, operational disruption, regulatory non-compliance, financial losses, and reputation damage.

Based on the results of this assessment, immediate attention should be given to the Critical vulnerabilities, followed by the High-risk findings before addressing the Medium-risk issue. In addition to applying the recommended technical fixes, the organization should strengthen its vulnerability management program by implementing regular security assessments, timely patch management, secure configuration standards, and continuous monitoring. Adopting these measures will significantly reduce the attack surface and improve the organization's overall cyber resilience against future threats.

Vulnerability Findings

The assessment identified six confirmed vulnerabilities in both the Kioptrix and the Metasploitable 2 laboratory environments. The vulnerability found in each of the cases was first identified automatically through manual scanning and then manually checked to ensure that the software versions used was in deed vulnerable as publicly documented.

The following tables summaries the affected services, describe each vulnerability, and explain what an attacker could achieve if the weaknesses were left unaddressed.

METASPLOITABLE 2 FINDINGS (nmap -A -p- -T4 10.100.41.251)			
Vulnerability	Affected Service	Description	Attacker's Goal
Vsftpd 2.3.4 Backdoor (CVE-2011-2523)	FTP / Port 21	A compromised version of vsftpd 2.3.4 contains a hidden backdoor that listens for a specially crafted username containing the characters "):". Once triggered, the service opens a root shell on port 6200 , allowing an attacker to gain complete control of the target system without needing valid login credentials.	Obtain immediate root access to the server and use the compromised system as a starting point for further attacks.
MySQL Unauthenticated Root Access (5.0.51a-3ubuntu5)	MySQL / Port 3306	MySQL service is configured to permit remote login using the root account without a password. This insecure configuration gives attackers unrestricted access to the database, allowing them to read, modify, or delete stored information and potentially compromise the host operating system.	Access sensitive database contents, manipulate stored records, and potentially gain control of the underlying server.
Postfix SMTP VRFY User Enumeration	SMTP / Port 25	The SMTP service allows the VRFY command, which reveals whether specific user accounts exist on the system. Although this weakness does not provide direct access, it supplies attackers with valid usernames that can later be used during password guessing or phishing attacks.	Identify legitimate user accounts to improve the success of credential-based attacks.

KIOPTRIX FINDINGS (nmap -A -p- -T4 10.0.2.4)

Vulnerability	Affected Service	Description	Attacker's Goal
OpenSSH 2.9p2 (Protocol 1.99) – Outdated SSH	SSH / Port 22	The server is running an outdated release of OpenSSH that still supports the obsolete SSHv1 protocol. Because this version is associated with multiple publicly disclosed vulnerabilities, attackers may exploit weaknesses in the service to obtain unauthorized access or compromise user credentials.	Gain privileged access to the server and use the compromised account to expand control over the system.
Apache httpd 1.3.20 with mod_ssl 2.8.4 / OpenSSL 0.9.6b	HTTP / Port 80	The web server is running an outdated version of Apache HTTP Server together with vulnerable mod_ssl and OpenSSL components. These versions are associated with known security flaws, including a buffer overflow vulnerability that may allow remote code execution under specific conditions.	Execute malicious code on the web server and use the compromised service as an entry point into the system

RPCBind Information Disclosure	RPC / Port 111	The RPCBind service responds to requests by listing registered Remote Procedure Call (RPC) services and their associated ports. Although this behaviour is expected, exposing this information to unauthorized users provides attackers with valuable reconnaissance data that can be used to identify additional services for further investigation or exploitation.	Collect information about available network services to support later stages of an attack.
--------------------------------	----------------	---	--

The three Critical findings require immediate attention because each can result in complete system compromise if successfully exploited. Although the High-rated vulnerabilities do not always provide direct access, they significantly increase the attack surface by supporting remote exploitation or revealing valuable information about the target environment. The Medium-rated SMTP finding presents a lower immediate risk but should still be addressed because it can assist attackers during reconnaissance and credential-based attacks.

Supporting Evidence

The figures below present the raw scan and vulnerability-lookup evidence collected during testing for each finding.

1. Vsftpd 2.3.4 Backdoor (FTP / Port 21)

```

/home/kali
Session Actions Edit View Help
kali@Toyin: ~ kali@Toyin: ~ kali@Toyin: ~
(kali@Toyin)-[~]
$ nmap -A -p- -T4 10.100.41.251
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-29 07:54 -0400
Nmap scan report for 10.100.41.251
Host is up (0.0015s latency).
Not shown: 65505 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ftp-syst:
|_STAT:
|_FTP server status:
|_Connected to 10.100.41.157
|_Logged in as ftp
|_TYPE: ASCII
|_No session bandwidth limit
|_Session timeout in seconds is 300
|_Control connection is plain text
|_Data connections will be plain text
|_vsFTPd 2.3.4 - secure, fast, stable
|_End of status
```

Nmap scan confirming the presence of vsftpd 2.3.4 on port 21

2. MySQL Unauthenticated Root Access (MySQL / Port 3306)

```

mysql-info:
Protocol: 10
Version: 5.0.51a-3ubuntu5
Thread ID: 8
Capabilities Flags: 40564
Some Capabilities: Support41Auth, SupportsCompression, SupportsTransactions, LongColumnFlag, ConnectWithDatabase, SwitchToSSLAfterH
andshake, Speaks41ProtocolNew
Status: Autocommit
Salt: ju5j>Z4d;8H>@c;SV5Gp*
```

service detection showing MySQL 5.0.51a-3ubuntu5 on port 3306

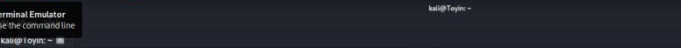
3. Postfix SMTP VRFY User Enumeration (SMTP / Port 25)

```

25/tcp    open  smtp          Postfix smtpd
|_ssl2:
|_SSLV2 supported
|_ciphers:
|_SSL2_RC4_128_EXPORT40_WITH_MD5
|_SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|_SSL2_DES_192_EDE3_CBC_WITH_MD5
|_SSL2_DES_64_CBC_WITH_MD5
|_SSL2_RC2_128_CBC_WITH_MD5
|_SSL2_RC4_128_WITH_MD5
|_smtp_commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITIME, DSN
|_ssl-date: 2026-06-30T12:11:21+00:00; +8s from scanner time.
|_ssl-cert: Subject: commonName=ubuntu04-base.localdomain/organizationName=OC0SA/stateOrProvinceName=There is no such thing outside US
|_countryName=XX
|_Not valid before: 2010-03-17T14:07:45
|_Not valid after: 2010-04-16T14:07:45
```

Postfix SMTP service with the VRFY command enabled.

4. OpenSSH 2.9p2 / Protocol 1.99 (SSH / Port 22)



```

kali@Toynin: ~$ nmap -A -p- -T4 10.0.2.4
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-06 11:05 -0400
Nmap scan report for 10.0.2.4
Host is up (0.0049s latency).
Not shown: 65529 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 2.9p2 (protocol 1.99)
|_ sshv1: Server supports SSHv1
|_ ssh-hostkey:
|_   1024 b8:74:6c:db:fd:8b:e6:66:e9:2a:2b:df:5e:6f:64:86 (RSA1)
|_   1024 8f:8e:5b:81:ed:21:ab:c1:80:e1:57:a3:3c:85:c4:71 (DSA)
|_   1024 ed:4e:a9:4a:06:14:ff:15:14:ce:da:3a:8b:db:e2:81 (RSA)

```

scan identifying **OpenSSH 2.9p2** with SSHv1 support enabled.

5. Apache httpd 1.3.20 with mod_ssl / OpenSSL (HTTP / Port 80)

```

- 1024 81:08:30:81:ed:21:a0:c1:00:01:57:43:3c:83:04:71 (RSA)
- 1024 ed:4e:a9:4a:06:14:ff:15:14:ce:da:3a:8b:dc:e2:81 (RSA)
sshhv: Server supports SSHv1
80/tcp open http Apache httpd 1.3.20 ((Unix) (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b)
http-methods:
- Potentially risky methods: TRACE
- http-server-header: Apache/1.3.20 (Unix) (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b
http-title: Test Page for the Apache Web Server on Red Hat Linux

```

scan identifying **Apache 1.3.20 with mod_ssl 2.8.4** and OpenSSL 0.9.6b on port

VULNERABILITIES

CVE-2002-0082 Detail

MODIFIED AFTER ENRICHMENT

This CVE record has been updated after NVD enrichment efforts were completed. Enrichment data supplied by the NVD may require amendment due to these changes.

QUICK INFO

CVE Dictionary Entry:
[CVE-2002-0082](#)

NVD Published Date:
03/15/2002

NVD Last Modified:
06/16/2026

Source:
MITRE

Description

The dbm and shm session cache code in mod_ssl before 2.8.7-1.3.23, and Apache-SSL before 1.3.22+1.46, does not properly initialize memory using the i2d_SSL_SESSION function, which allows remote attackers to use a buffer overflow to execute arbitrary code via a large client certificate that is signed by a trusted Certificate Authority (CA), which produces a large serialized session.

Metrics

CVSS Version 4.0	CVSS Version 3.x	CVSS Version 2.0
------------------	------------------	-------------------------

NVD enrichment efforts reference publicly available information to associate vector strings. CVSS information contributed by other sources is also displayed.

CVSS 2.0 Severity and Vector Strings:



NIST: NVD

Base Score: 7.5 HIGH

Vector: (AV:N/AC:L/Au:N/C:P/E:P/A:P)

80.

CVE-2002-0082 record confirming the **mod_ssl Apache 1.3.20** buffer overflow vulnerability.

6. RPCBind Information Disclosure (RPC / Port 111)

```
111/tcp open rpcbind 2 (RPC #100000)
rpcinfo:
  program version port/proto service
  100000 2 111/tcp rpcbind
  100000 2 111/udp rpcbind
  100024 1 32768/tcp status
  100024 1 32768/udp status
```

Rpc info output identifying RPC services exposed through **RPCBind on port 111.**

VULN INFORMATION			
CVE-1999-0632 Detail			
MODIFIED AFTER ENRICHMENT			
This CVE record has been updated after NVD enrichment efforts were completed. Enrichment data supplied by the NVD may require amendment due to these changes.			
Description The RPC portmapper service is running.			
Metrics			
CVSS Version 4.0	CVSS Version 3.x	CVSS Version 2.0	
NVD enrichment efforts reference publicly available information to associate vector strings. CVSS information contributed by other sources is also displayed.			
CVSS 3.x Severity and Vector Strings:			
NIST: NVD	Base Score: NA	NVD assessment not yet provided.	
ADP: CISA ADP	Base Score: 7.3 High	Vector: CVSS:3.1/(AV:N)/(AC:L)/(PR:N)/(UI:N)/(S:C)/(C:H)/(A:L)	
QUICK INFO CVE Dictionary Entry: CVE - 1999-0632 NVD Published Date: 01/01/1999 NVD Last Modified: 06/16/2026 Source: MITRE			

CVE-1999-0632 record confirming the information disclosure risk of an exposed **RPC portmapper service.**

Risk Assessment

Metasploitable 2

Vulnerability	Likelihood	Impact	Risk Rating
Vsftpd 2.3.4 Backdoor	High	Medium	High
MySQL 5.0.51a-3ubuntu5	High	Medium	High
Postfix Smtpd (VRFY)	Medium	Low	Low

Kioptrix

Vulnerability	Likelihood	Impact	Risk Rating
OpenSSH 2.9p2 (Protocol 1.99)	High	High	High
Apache httpd 1.3.20 / mod_ssl / OpenSSL	High	High	High
RPCBind Information Disclosure	High	High	High

Short Explanation For Each Rating (METASPLOITABLE 2)

1. Vsftpd 2.3.4 Backdoor

This vulnerability presents the highest level of risk because it can be exploited without requiring valid user credentials. Triggering the hidden backdoor immediately provides the attacker with a root shell, giving unrestricted control over the operating system. Since publicly available exploit code exists and exploitation is straightforward, the likelihood of compromise is extremely high. For these reasons, this vulnerability is classified as **High** and should be addressed immediately.

2. MySQL Unauthenticated Root Access

Allowing remote access to the MySQL root account without a password creates a serious security weakness. An attacker can connect directly to the database, access confidential information, modify records, or delete important data without first bypassing authentication. Depending on the system configuration, this level of access may also provide opportunities to compromise the underlying server. Because exploitation requires very little effort and the potential impact is severe, this finding is appropriately rated **High**.

3. Postfix SMTP VRFY User Enumeration

The enabled VRFY command allows remote users to determine whether email accounts exist on the server. Although this does not immediately expose the system, it provides attackers with a list of valid usernames that can be used during password-spraying, brute-force, or phishing attacks. Because the vulnerability mainly supports reconnaissance rather than direct exploitation, the impact is lower than the other findings. For this reason, the overall risk is assessed as Medium.

Short Explanation For Each Rating (KIOPTRIX)

1. OpenSSH 2.9p2 (Protocol 1.99)

The SSH service is running an outdated version that still supports the obsolete SSHv1 protocol. During reconnaissance, this version can easily be identified using standard scanning tools such as Nmap. Legacy SSH implementations have several publicly documented vulnerabilities that may allow attackers to obtain privileged access if successfully exploited. Since SSH normally provides administrative access to a system, compromising this service could result in complete control of the host. Consequently, the overall risk is assessed as **Critical**.

2. Apache HTTP Server 1.3.20 with mod_ssl/OpenSSL

The web server is running software that has reached end-of-life and contains several publicly documented security vulnerabilities. Although successful exploitation depends on the affected components being exposed and correctly targeted, reliable exploit techniques are available for this software combination. If an attacker achieves remote code execution, the web server could become an entry point for further privilege escalation and compromise of the host. Considering both the likelihood and potential impact, this vulnerability is rated **High**.

3. RPCBind Information Disclosure

RPCBind does not directly provide attackers with administrative access; however, it reveals valuable information about available RPC services and their associated ports. This information can significantly assist reconnaissance by allowing attackers to identify additional services that may contain exploitable weaknesses. While the vulnerability alone is unlikely to compromise the system, it increases the effectiveness of later attacks and therefore represents a **High risk**.

Recommended Controls

The controls below are grouped by vulnerability and addresses both the immediate technical fix and supporting compensating controls.

1. Vsftpd 2.3.4 Backdoor

The compromised vsftpd 2.3.4 installation should be removed immediately and replaced with a trusted, vendor-supported version obtained from an official software repository. Before installation, the integrity of the software should be verified using vendor-provided checksum to ensure that the package has not been tampered with.

Access to the FTP service should also be limited to authorized hosts through firewall rules or access control lists. Where possible, intrusion detection or intrusion prevention systems such as Snort or Suricata should be configured to detect suspicious FTP activity and known backdoor trigger patterns.

Replacing the compromised software removes the backdoor completely rather than attempting to block it with network controls alone. Restricting access further reduces the number of systems capable of reaching the service.

2. MySQL Unauthenticated Root Access

Remote login using the root account should be disabled. Administrative access should be performed using named accounts with strong authentication, while the root account should only accept local connections where possible.

Database auditing should also be enabled to record login attempts, privilege changes, and other sensitive administrative actions. These logs should be forwarded to a Security Information and Event Management (SIEM) platform so that suspicious behaviour can be detected quickly.

Restricting privileged access significantly reduces the possibility of database compromise, while audit logging provides visibility into attempted or successful attacks.

3. Postfix SMTP VRFY User Enumeration

The VRFY command should be disabled within the Postfix configuration to prevent attackers from confirming whether user accounts exist on the server.

In addition, automated protection mechanisms such as Fail2Ban should be deployed to identify repeated SMTP probing or password guessing attempts and temporarily block offending IP addresses. Disabling VRFY removes an unnecessary source of information that attackers commonly use during reconnaissance, while automated blocking helps limit repeated abuse of the mail service.

4. OpenSSH 2.9p2 (Protocol 1.99)

The existing OpenSSH installation should be upgraded to a supported release that no longer includes SSH Protocol 1. After the upgrade, SSHv1 should be permanently disabled and only SSH Protocol 2 should be permitted.

Additional hardening measures, such as disabling direct root login, enforcing public key authentication, and regularly reviewing SSH configuration settings, should also be implemented. Updating the software removes known vulnerabilities, while configuration hardening reduces the likelihood that attackers can misuse the SSH service even if it remains exposed to the network.

5. Apache HTTP Server 1.3.20 with mod_ssl/OpenSSL

The outdated Apache, mod_ssl, and OpenSSL packages should be replaced with supported versions that receive regular security updates. After upgrading, obsolete SSL protocols and weak cryptography ciphers should be disabled before the web server is returned to production.

A follow-up vulnerability scan should then be carried out to verify that the vulnerable software versions have been removed successfully. Updating the affected software eliminates publicly known vulnerabilities, while post-remediation testing confirms that the corrective actions have been applied successfully.

6. RPCBind Information Disclosure

If RPC services are no longer required, the RPCBind service should be disabled completely.

Where RPC services remain necessary for operational reasons, access should be restricted to authorized internal hosts through firewall rules or network segmentation. External systems should not be permitted to query the service. Reducing unnecessary exposure limits the amount of information available to attackers and decreases the likelihood of reconnaissance leading to further compromise.

HOW THESE CONTROLS REDUCES RISK

The recommended controls focuses on addressing the underlying causes of the identified vulnerabilities rather than simply reducing their visibility. Replacing unsupported or compromised software removes known security flaws, while secure configuration changes eliminate unnecessary exposure that attackers commonly exploit.

Restricting access to critical services, such as MySQL, FTP, SSH, and RPCBind, limits opportunities for unauthorized users to interact with vulnerable systems. Where vulnerabilities cannot be eliminated immediately, additional safeguards such as intrusion detection, audit logging, and automated blocking provide an extra layer of defence by detecting suspicious activity and supporting incident response.

Applying these recommendations together follows the principle of defence in depth, where multiple security controls work together to reduce the likelihood and impact of a successful attack. Although no single control can

completely eliminate cyber risk, implementing the recommendations in combination would significantly improve the organisation's ability to prevent, detect, and respond to future security incidents.

Recommended Security Policies

Technical controls alone cannot eliminate security risks. To maintain a secure environment over time, Apex Healthcare Solution Limited should support those controls with formal security policies that define staff responsibilities, establish minimum security requirements, and promote consistent security practices across the organization. The following are Policies recommended.

1. Patch Management Policy

This Policy ensures that security updates are identified, tested, and deployed in a timely manner. By monitoring vendor advisories, prioritizing critical patches, and testing updates before deployment, the organization can reduce the risk of exploiting known vulnerabilities while maintaining system stability.

Purpose : During the assessment many of the vulnerabilities identified were caused by outdated software that no longer receives security updates. This ensures the operating systems, applications, and network services are regularly updated to address newly discovered vulnerabilities before they can be exploited.

NOTE: A structured patch management process prevents vulnerabilities such as the outdated Apache HTTP Server, OpenSSH, and vsftpd versions from remaining exposed within the environment. Regular updates significantly reduce the attack surface and lower the likelihood of successful exploitation.

Why Apex Healthcare Solution Needs it

Apex Healthcare Solution had Several vulnerabilities identified during the assessment were linked to outdated software versions that contained publicly known security flaws. By implementing a structured process for monitoring vendor advisories, testing updates, and deploying critical patches promptly, the organisation can significantly reduce its exposure to known attacks while maintaining system stability.

Mitigation

This policy would help mitigate vulnerabilities associated with the outdated **Vsftpd 2.3.4**, **OpenSSH 2.9p2**, and **Apache HTTP Server 1.3.20** services by ensuring that unsupported or vulnerable software is updated before it can be exploited.

2. Access Control Policy

This Policy limits user access based on job responsibilities by applying the Principle of Least Privilege. Regular permission reviews and the removal of unnecessary or inactive accounts help reduce the risk of unauthorized access and improve overall system security.

Purpose: The assessment identified services that granted excessive privileges or exposed sensitive resources without adequate restrictions. Implementing this control would reduce the risk associated with unrestricted MySQL root access and strengthen protection for administrative services such as SSH. Limiting privileged access also reduces the potential impact of compromised accounts. This also ensures users receive only the permissions necessary to perform their duties, reducing the risk of unauthorized access.

Why Apex Healthcare Solution Needs it

This Policy ensure that users at the Apex Healthcare Solution are granted only the level of access required to perform their responsibilities. For Apex Healthcare Solution Limited, this is particularly important because healthcare systems store sensitive patient and organisational information that should only be accessible to authorized personnel. Applying the Principle of Least Privilege, regularly reviewing user permissions, and removing unnecessary privileged accounts would reduce the risk of unauthorised access

Mitigation

This directly help mitigate the **MySQL Unauthenticated Root Access** vulnerability and strengthen access to administrative services such as **OpenSSH**, limiting the impact of compromised accounts.

3. Vulnerability Management Policy

This Policy establishes a continuous process for identifying, assessing, prioritizing and remediating security vulnerabilities across organizational assets. It also defines responsibilities for regular vulnerability scanning, reporting and remediation verification. The vulnerabilities identified during this assessment demonstrate that systems can remain insecure for extended periods when regular assessments are not performed.

Purpose: establishes a structured process for identifying, assessing, and remediating security vulnerabilities. For a healthcare organization, it helps protect sensitive patient data, reduce cyber risks, and ensure that security weaknesses are addressed before they can be exploited.

Why Apex Healthcare Solution Needs it

Apex Healthcare solution needs this Policy Because it provides a structured approach for continuously identifying, assessing, and remediating security weaknesses before they can be exploited. The assessment demonstrated that several vulnerabilities had remained present because they had not been detected or addressed through routine security reviews. By introducing regular vulnerability scanning, risk assessments, remediation tracking, and verification, Apex Healthcare Solution Limited can better protect sensitive patient information and reduce its overall cyber risk.

Mitigations

Vsftpd 2.3.4 Backdoor Ensures outdated and vulnerable FTP services are identified and upgraded before they can be exploited.

OpenSSH 2.9p2 (Protocol 1.99) –Supports the timely replacement of unsupported SSH versions with secure, up-to-date releases.

Apache HTTP Server 1.3.20 with mod_ssl/OpenSSL Promotes regular patching and remediation of vulnerable web server software.

4. Password and Authentication Policy

This Policy protects user accounts by enforcing strong passwords, requiring Multi-Factor Authentication (MFA) for administrative accounts where possible, and preventing unauthorized access through account lockout controls and secure authentication practices.

Purpose : Weak authentication practices increase the likelihood of unauthorized system access. Strong authentication controls reduce the effectiveness of password-spraying, brute-force attacks, and credential theft. This policy establishes minimum requirements for creating, protecting, and managing user credentials across the organization. These measures also help protect services such as SSH, MySQL, and SMTP from unauthorized access attempts.

Why Apex Healthcare Solution Needs it

For Apex Healthcare Solution Limited, this policy strengthens the protection of administrative services such as **OpenSSH**, **MySQL**, and **SMTP**. This Policy strengthens account security by enforcing strong password requirements, implementing Multi-Factor Authentication (MFA) for administrative accounts where possible, and applying secure authentication controls across the organization. These measures reduce the likelihood of unauthorized access resulting from weak passwords, credential theft, or brute-force attacks.

Mitigation: MySQL Unauthenticated Root Access this Prevents unrestricted administrative access by enforcing strong authentication for privileged accounts. **OpenSSH 2.9p2 (Protocol 1.99)** also Reduces the risk of unauthorized SSH access through strong passwords and Multi-Factor Authentication (MFA).

5. Secure Configuration Management Policy

This Policy ensures that systems are securely configured by removing unnecessary services, disabling insecure default settings, and regularly reviewing configurations. This helps reduce the attack surface and strengthens the organization's overall security.

Purpose: Several vulnerabilities identified during the assessment resulted from insecure default configurations rather than software flaws alone. Establishing secure configuration standards helps ensure that unnecessary features and services are disabled before systems are deployed. Applying secure configuration standards would reduce information leakage through RPCBind, prevent SMTP VRFY user enumeration, and strengthen the security of publicly accessible services.

Why Apex Healthcare Solution Needs it: Apex Healthcare Solution Need this Policy because it establishes consistent security standards for all systems before they are placed into operation. During the assessment, several findings were linked to insecure default configurations and unnecessary services rather than software vulnerabilities alone

Mitigation This policy mitigate issues such as **RPCBind Information Disclosure, Postfix SMTP VRFY User Enumeration**, and other risks associated with insecure system configurations.

Conclusion

This Vulnerability Assessment exercise successfully identified six security vulnerabilities across the Kioptrix and Metasploitable 2 laboratory environments representing the network infrastructure of Apex Healthcare Solutions. The findings showed that the most significant security weaknesses resulted from outdated software, insecure system configurations, excessive privileges, and unnecessary exposure of network services. If left unaddressed, these weaknesses could allow attackers to gain unauthorized access, compromise sensitive information, or use the affected systems as a stepping stone for further attacks.

The assessment also demonstrated the importance of combining manual vulnerability scanning with verification. While tools such as Nmap identified vulnerabilities and manual analysis was necessary to confirm how exploitable they are, and reduce false-positive results. This approach provided a more accurate understanding of the security risks present within the environment.

To reduce these risks, Apex Healthcare Solution Limited should give immediate priority to remediating the Critical vulnerabilities before addressing the High and Medium findings. Applying software updates, strengthening system configurations, enforcing stronger authentication controls, and implementing the recommended security policies will significantly improve the organization's security and reduce the likelihood of future attacks.

Cybersecurity is an ongoing process rather than a one-time activity. Regular vulnerability assessments, timely patch management and continuous security monitoring should form part of the organization's long-term security strategy. After the recommended remediation measures have been implemented, a follow-up assessment should be conducted to verify that the identified vulnerabilities have been successfully resolved and that no new security weaknesses have been introduced.